

Manual de Administração de Usuários

Planejador Financeiro · cadastro privado com Supabase Auth, Edge Function e MFA/TOTP

1. Modelo de segurança

- O aplicativo não oferece cadastro público.
- O administrador é identificado pelo UUID imutável do Supabase Auth, armazenado no secret `APP_ADMIN_USER_IDS`.
- A área administrativa requer sessão MFA AAL2. Cada criação exige confirmação TOTP recente, válida por até cinco minutos.
- A chave `service_role` fica exclusivamente na Edge Function do Supabase. Ela nunca vai para GitHub, Vercel, arquivo `.env` do frontend ou variável `VITE_*`.
- A conta nova recebe senha temporária e não acessa os dados financeiros antes de definir uma senha própria.

2. Preparação no Supabase

1. Em **Authentication > Users**, copie o **User UID** da conta administrativa.
2. No aplicativo, abra **Segurança**, ative MFA/TOTP, saia e entre novamente confirmando o código.
3. Em **Authentication > Providers > Email**, desative **Allow new users to sign up**.
4. Em **Edge Functions > Secrets**, crie `APP_ADMIN_USER_IDS` com o UUID. Para vários administradores, separe UUIDs por vírgula.
5. Crie `APP_ALLOWED_ORIGINS` com a URL exata de produção e, se necessário, homologação, separadas por vírgula. Não use curinga.
6. Publique a Edge Function primeiro em homologação.

```
npx supabase login
npx supabase link --project-ref SEU_PROJECT_REF
npx supabase functions deploy admin-users
```

Atenção: confirme o projeto de destino antes de executar comandos. Este pacote local não altera Supabase nem Vercel automaticamente.

3. Configuração da Vercel

O frontend usa somente `VITE_SUPABASE_URL` e `VITE_SUPABASE_ANON_KEY`. Nunca cadastre `service_role`, UUID administrativo ou senha temporária na Vercel.

Faça um Preview Deployment apontado para homologação, execute os testes e só então promova para Production.

4. Criar um usuário

1. Entre na conta administrativa e confirme o MFA.
2. Abra **Configurações > Administração de usuários**.
3. Informe nome e e-mail e use **Gerar** para criar uma senha temporária forte.
4. Digite o código atual do autenticador e clique **Criar usuário**.
5. Entregue e-mail e senha em canais separados e seguros.
6. No primeiro acesso, o usuário define uma senha própria e entra novamente.

5. Validação antes de produção

- ☐ Visitante não encontra cadastro e o Supabase recusa `signUp`.
- ☐ Usuário comum não vê a administração e recebe HTTP 403 em chamada direta.
- ☐ Administrador sem MFA não lista nem cria usuários.
- ☐ Administrador com MFA lista e cria uma conta; e-mail duplicado recebe resposta neutra.
- ☐ Conta nova fica bloqueada na troca inicial de senha.
- ☐ Depois da troca, a conta acessa somente os próprios dados por RLS.
- ☐ Login, leitura, criação, edição e exclusão financeira continuam funcionando.

6. Publicação e rollback

Ordem: secrets e cadastro público desativado; Edge Function; Preview Vercel; testes; Production.

Não há migração de banco nesta funcionalidade e os dados existentes não são modificados. Para rollback, promova o deployment estável anterior na Vercel e publique novamente a versão estável da função. Não exclua usuários ou dados. Manter o cadastro público desativado não impede o login de contas existentes.